

01

1 AGO 2022

US\$ 190M

Nomad Bridge

— "O primeiro hack 'democrático' —
centenas copiaram"

ZERO-HASH BYPASS · CRITICAL

Após o exploit inicial, centenas de pessoas copiaram a transação e drenaram o resto

O QUE ACONTECEU

Nomad era uma bridge cross-chain que usava **optimistic verification** — um modelo onde mensagens são aceitas após um período sem disputa.

Um upgrade de rotina **inicializou o trusted root como 0x00**. O contrato usava **mapping** para checar se um root era aceito — e em Solidity, valores não-inicializados retornam **0**.

Resultado: **acceptableRoot[0x00] = true** por padrão. Qualquer mensagem com root 0x00 era válida.

O mais surpreendente: após o primeiro exploit, **centenas de pessoas** simplesmente copiaram a transação, trocando apenas o endereço de destino, e drenaram os US\$190M restantes.

CONTRATO VULNERÁVEL

```
2
returns
acceptableRoot(0x00) → TRUE //
Qualquer mensagem é válida! _send(_message); } }
```

Lição

Testes de invariante devem cobrir **estado pós-upgrade**. Nunca confie em valores default de mappings para segurança.

04

COMO O ATAQUE FUNCIONOU

PASSO 1

Upgrade de rotina no contrato Replica

**PASSO 2**

Trusted root inicializado como 0x00

**PASSO 3**

mapping(0x00) → default uint256 = 0

confirmAt[0x00] setado como 1 no upgrade

acceptableRoot(0x00) = TRUE

**PASSO 4**

Atacante envia mensagem com root 0x00

require(acceptableRoot) → PASSA

**PASSO 5**

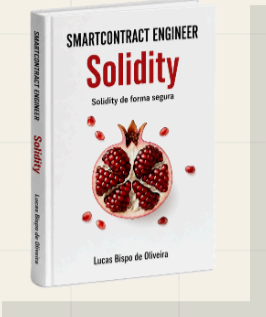
Centenas copiam a tx, trocam endereço

"Hack democrático" – US\$190M drenados

VERIFIQUE NA BLOCKCHAIN

Uma das transações do Ataque
etherscan.io/tx/0xa5fe9d...6c2e

Contrato Nomad Replica
etherscan.io/address/0xB9233...7bd8



Solbook — Smartcontract Engineer

Entenda por que upgrades são o momento mais perigoso de um contrato